

4. HISTORY OF THE PCI DSS

Where the PCI DSS came from,
and how they have evolved over
the years.



FUNDAMENTALS

FUNDAMENTALS HISTORY OF THE PCI DSS

PCI DSS, also known as the Payment Card Industry Data Security Standards, are a set of directives for how credit/debit card data should be stored and transmitted.

- They were created and are maintained by the PCI-SSC, or Payment Card Industry Security Standards Council;

As of March 2024, the PCI DSS are version v4.0.0:

- The first version was released in 2004. Before the PCI DSS, every card company (VISA, MasterCard) had their own security standards, which made difficult for merchants wanting to accept payments from multiple companies;
- All the card companies eventually came together to standardize security controls - this is the result;

FUNDAMENTALS

HISTORY OF THE PCI DSS

At the time of its creation, in 2004, payment fraud was rising considerably (and it has not slowed down, unfortunately).

- So, representatives of these brands came together to define a unified set of controls to protect all card data;
- Remember that, before, issuing banks were responsible;

The PCI DSS continue to evolve in every release, and have gone through several major iterations:

- 1.1 established the firewall requirement (Req. 1);
- 1.2 established standards for AV software;
- 4.0 established a “Customized Approach” for controls;
-
- The standards evolve with the safety requirements of the industry (new types of attacks, technology, etc);





FUNDAMENTALS

FUNDAMENTALS HISTORY OF THE PCI DSS

Any new release of the PCI DSS is a very organic process with its own lifecycle (usually, three years):

- In the first year, the standards are published and made effective, and implementation of these begins;
- In the second year, the PCI SSC receives initial feedback from early adopters in order to revise this version, which is then reviewed. It's also when the previous standards start to be retired;
- The third year is mostly about maintenance, as the standards are revised according to feedback, and the final version is published;

FUNDAMENTALS

HISTORY OF THE PCI DSS

EXAMPLES

/01 A PRESENT DANGER

The reason why the PCI DSS were created still remains a threat - payment fraud is a very significant number, and continues on the rise.

/02 LOW NUMBERS

As of 2020, only 27.9% of global organizations had adopted PCI DSS. This means that there is still a large number of vulnerable merchants.

/03 3.0 AND PENTESTING

Version 3.0 was radical in terms of penetration testing. Before it, merchants could make small scans. After, major, periodic penetration testing became required.

FUNDAMENTALS

HISTORY OF THE PCI DSS

KEY TAKEAWAYS

/01 CCs CAME TOGETHER

The PCI-SSC was formed by representatives of the various card companies, looking to standardize directives for card data transfer/storage, the DSS.

/02 EVOLUTIONS AS REQUIRED

The PCI DSS continually evolve in each iteration, both based on the feedback received by early implementers, but also technology/attack trends.

/03 A 3-YEAR LIFECYCLE

Each PCI DSS version (as of v4) has a 3-year lifecycle. In Y1, standards are implemented. In Y2, feedback is reviewed and old standards. Y3 brings final revision.